Module 02: Reconnaissance

Information Gathering & NMAP

Project Athena

Information Gathering

Definition

Collect, analyze and catalog data about a target until it becomes actionable.

- **Network**: IPs, domains, DNS
- **Systems**: OS, services, versions
- **People**: names, email format, roles

NMAP

What is NMAP?

> The network scanner. Since 1997. Free, scriptable, everywhere.

1. **Host discovery** – who is online?
2. **Port scanning** – what is open?
3. **Version detection** – what is running?
4. **OS detection** – what is it running on?

Host Discovery

```
nmap -sn 192.168.1.0/24   # ping sweep
nmap -Pn 192.168.1.10     # skip ping, assume up
nmap -PR 192.168.1.0/24   # ARP, best on local LAN
```

Port Scanning

```
nmap -sS 192.168.1.10          # SYN scan (root)
nmap -sT 192.168.1.10          # full connect
nmap -p- 192.168.1.10          # all 65535 ports
nmap --top-ports 100 10.0.0.1  # the usual suspects
```

Don't Forget UDP

A TCP scan finds no UDP services. None.

DNS, SNMP, TFTP and NTP are invisible until you ask for them.

```
1  sudo nmap -sU --top-ports 20 192.168.1.10
```

A full UDP sweep takes hours. Scan the top ports.

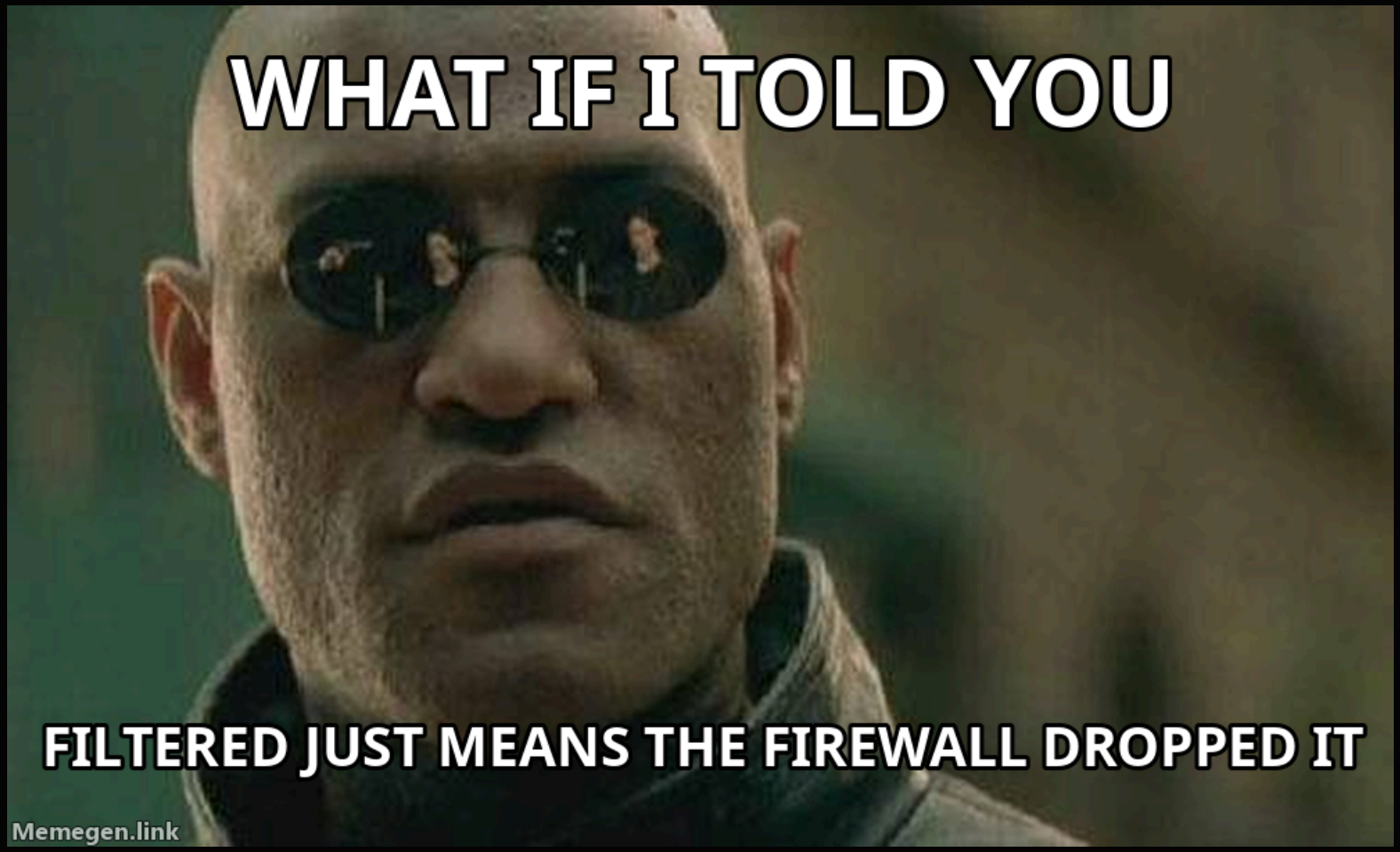
Versions and OS

```
nmap -sV 192.168.1.10   # service versions
nmap -O  192.168.1.10   # OS fingerprint (root)
nmap -A  192.168.1.10   # everything, loud
```

```
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.2p1
80/tcp   open  http    Apache 2.4.41
```

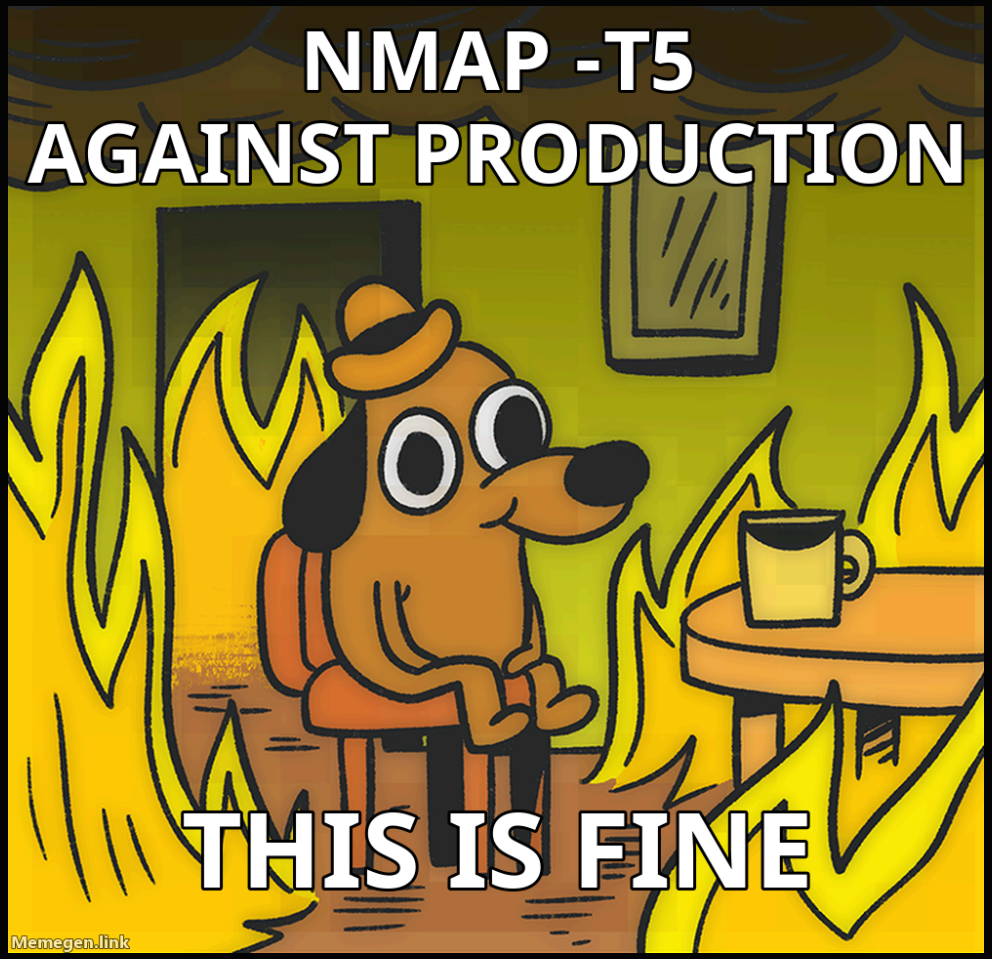
Port States

- **open** – a service answers
- **closed** – reachable, nothing listening
- **filtered** – a firewall dropped the probe
- **open|filtered** – UDP, can’t tell


WHAT IF I TOLD YOU
FILTERED JUST MEANS THE FIREWALL DROPPED IT
Memegen.link

Timing: -T0 to -T5

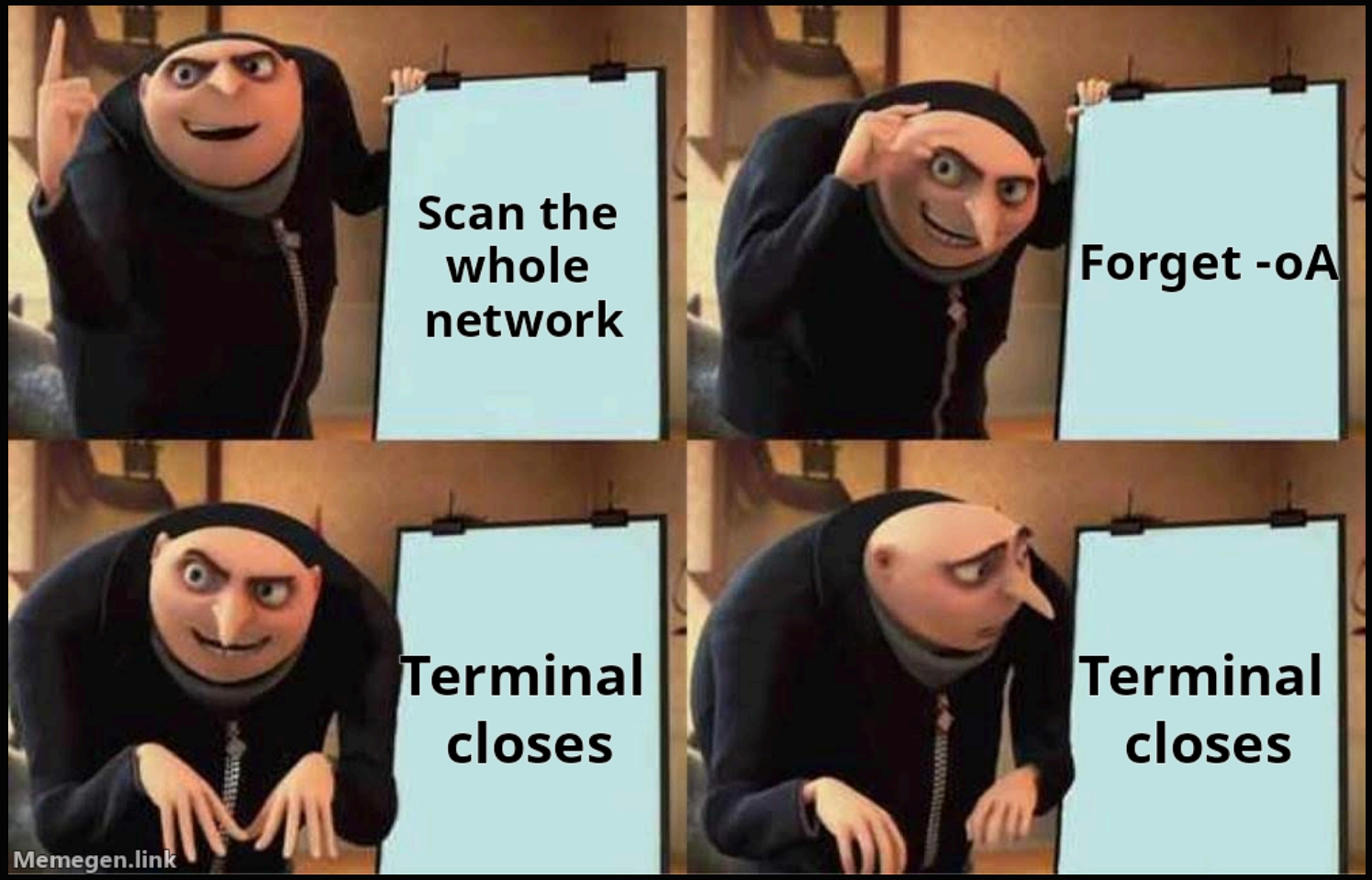
- **T0/T1** - paranoid, slow, hours
- **T3** - default
- **T4** - fast, fine on good networks
- **T5** - insane, misses results, may break things


NMAP -T5
AGAINST PRODUCTION
THIS IS FINE
Memegen.link

Always Save Output

```
1  nmap -oA scan 192.168.1.10   # .nmap + .xml + .gnmap
```

You will need it again. You will not remember the flags.


Scan the whole network
Forget -oA
Terminal closes
Terminal closes
Memegen.link

NSE: Scripting Engine

NSE Scripts

600+ Lua scripts in categories: default, vuln, discovery, …

```
nmap -sC target                                  # safe defaults
nmap --script=vuln target                        # known vulns
nmap --script=ssl-enum-ciphers -p 443 target
```

The Workflow

```
nmap -sn 10.0.0.0/24 -oA 1-hosts            # 1. who is up
nmap -iL hosts.txt -p- --open -oA 2-ports   # 2. what is open
nmap -sV -sC -O -oA 3-services target       # 3. what is it
nmap --script=vuln -oA 4-vulns target       # 4. what is wrong
```

Enumeration

What is Enumeration?

Scanning finds the door. Enumeration reads the nameplate.

Pull users, shares, configs and policies out of each service.

SMB (139/445)

```
smbclient -L //192.168.1.10 -N          # list shares, no password
smbclient //192.168.1.10/public -N -c ls
enum4linux -a 192.168.1.10              # all of it, plus users
```

`-N` is an anonymous session. No exploit needed.

SNMP (161/udp)

```
snmpwalk -v 2c -c public 192.168.1.1 1.3.6.1.2.1.1
onesixtyone -c community.txt 192.168.1.1
```

- Hostname, location, contact, interfaces
- Default community strings: `public`, `private`. Still common.

LDAP and DNS

```
ldapsearch -x -h 192.168.1.10 -b "dc=example,dc=com"
dig @ns1.example.com example.com AXFR   # zone transfer
amass enum -d example.com               # subdomains
```

Rules

Before You Scan

Written authorization

Scope, ports, timing, time window.

- A fast full scan on an old embedded device is a denial of service
- Log every command with a timestamp

Defending

- Turn off what you don’t need
- Change SNMP strings, block anonymous SMB, no zone transfers
- Strip version banners
- Alert on port sweeps

Remember

- `-sn` → `-p-` → `-sV -sC` → `--script=vuln`
- Always `-oA`
- Enumeration turns ports into usernames
- Authorization first

Resources

- nmap.org/book
- nmap.org/nsedoc
- HackTheBox / TryHackMe

Module 02: Reconnaissance

Information Gathering & NMAP

Project Athena